PENSE-BÊTE · RAPPORT ET STRATÉGIE

Cyberattaques DGFiP (2026) : Rapport ANSSI n°3033

00-10 ANSSI - Rapport d'incident sur les cyberattaques ayant touché la DGFiP (2026) — source : fiche de révision du module (gemma4, 31/10/2026)

À RETENIR

1. L'attaquant **Zerobytes** a exploité des faiblesses d'**identité**, d'**architecture** et de **détection** pour exfiltrer des données sans être détecté.
2. **E-Contact** pillé en deux vagues (**11 Go** fin juin, **3 Go** fin juillet : 353 000 particuliers, 252 000 professionnels) ; incident distinct sur le **SPDC** (cadastre, « 2 millions de Français »).
3. L'attaquant est entré par le **RIE** depuis des infrastructures compromises de l'**Éducation nationale**, avec des identifiants volés par **infostealers** sur des appareils personnels.

Bilan des exfiltrations

678 437
enregistrements E-Contact
353 000 particuliers / 252 000 pros

2 000 000
Français concernés (SPDC)
données cadastrales

11 Go
volume 1ère vague (juin)
entre le 22/06 et le 25/06

3 Go
volume 2ème vague (juillet)
détectée le 23/07

Portails et accès

Portail	Usage / Cible	Vulnérabilité
PIGP	Agents DGFiP (RH, messagerie)	Pas d'authentification multifacteur
ADER	Applications DGFiP via RIE	Pas de supervision par le SOC
APEX	Partenaires (notaires, géomètres)	OTP par courriel insuffisant

Chronologie de l'attaque

2-8 mai un compte se connecte au **PIGP** depuis des IP malveillantes (France, Inde)

7 juin passage du PIGP au portail **ADER** depuis le RIE, non vu (ADER non supervisé)

9 juin le **COSSIM** (Éducation nationale) partage 17 marqueurs à tous les CSIRT

24-25 juin exfiltration E-Contact ; mot de passe réinitialisé mais **session non coupée**

22 juillet seconde exfiltration E-Contact (3 Go), compte réinitialisé le 23

27 juil.-8 août exfiltration du **SPDC** via le poste d'un géomètre-expert (APEX)

12-13 août **Zerobytes** revendique les vols ; ANSSI notifie la DGFiP

13 et 18 août coupure définitive d'ADER puis du PIGP pour les agents

Recommandations de remédiation

Axe	Mesures clés
Identité	**MFA** partout, second facteur résistant (jeton physique, application), jamais d'appareil personnel
Supervision	toutes les applications dans un **SIEM**, quotas de données et de requêtes, blocage par géolocalisation et réputation IP
Réseau	segmentation plus fine, filtrage des flux entre ministères sur le RIE
Réinitialisation	**révoquer les sessions actives** partout ; nettoyer l'appareil infecté
Postes	mises à jour mensuelles, EDR, antivirus, VPN toujours actif

Acteurs impliqués

- **ANSSI** : autorité nationale, rédacteur du rapport.
- **DGFiP** : victime des exfiltrations.
- **Zerobytes** : acteur malveillant.
- **COSSIM** : SOC de l'Éducation nationale (a alerté sur les marqueurs).
- **CSIRT Finances** : CSIRT ministériel, informé par l'ANSSI, prévient le SOC de la DGFiP.

Le constat de l'ANSSI

> L'attaque n'est pas sophistiquée : elle résulte de l'exploitation de faiblesses ordinaires dans l'identité, l'architecture et la détection.

Pièges et confusions

- ⚠ Confondre l'origine de l'attaque : ce n'est pas une force brute, mais l'usage d'identifiants volés par **infostealers**.
- ⚠ Croire que la réinitialisation du mot de passe suffit : elle ne coupe pas les sessions actives et ne nettoie pas l'appareil infecté.
- ⚠ Confondre les portails : le **PIGP** est pour les agents, l'**APEX** est pour les partenaires externes.
- ⚠ Oublier le rôle du **RIE** : il a servi de vecteur de latéralisation depuis l'Éducation nationale.
- ⚠ Les deux vagues de juin et juillet visent **E-Contact** ; le SPDC (cadastre) est un incident distinct, via le portail APEX.

Sigles et définitions

Infostealer	logiciel malveillant volant les identifiants
Credential stuffing	bourrage d'identifiants volés
Scraping	extraction automatique de données web
Latéralisation	progression d'un attaquant entre systèmes
SOC	centre opérationnel de sécurité
SIEM	gestion et corrélation des journaux de sécurité
EDR	détection et réponse sur les terminaux
OTP	mot de passe à usage unique

Auto-test

1. Quelle est la cause principale de la compromission des comptes ?
2. Quel portail a permis le vol des données cadastrales ?
3. Combien de données ont été exfiltrées lors de la première vague ?
4. Pourquoi la réinitialisation du mot le 24 juin a échoué ?
5. Quels sont les 3 domaines de faiblesses identifiés ?

Réponses : **1.** Des infostealers sur des appareils personnels non administrés. · **2.** Le portail APEX (via un géomètre-expert). · **3.** 11 Go. · **4.** Elle n'a pas interrompu la session ouverte ni l'exfiltration en cours. · **5.** L'identité, l'architecture et la détection.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.